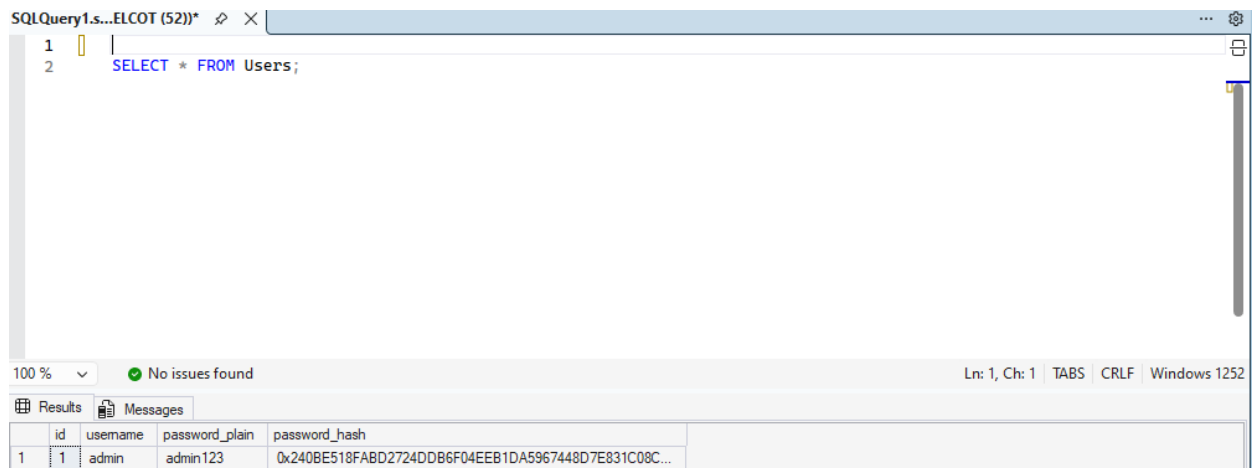


MSSQL for Pentester: Hashing

Hashing in SQL is the process of converting data into a fixed-length string or number using a **hash function** for various purposes, including data integrity, improved performance in indexing and joining, and security.

In this lab we are going to crack the hash that we gathered form SQL database.



This is the SQL database where the password stored in hash.

Now we are going to use the tool called PowerUpSQL.

PowerUpSQL includes functions that support SQL Server discovery, weak configuration auditing, privilege escalation on scale, and post exploitation actions.

```
PS C:\PowerUpSQL-master\PowerUpSQL-master> Get-SQLInstanceLocal

ComputerName      : LENOVO
Instance          : LENOVO
ServiceDisplayName : SQL Server (MSSQLSERVER)
ServiceName       : MSSQLSERVER
ServicePath       : "C:\Program Files\Microsoft SQL Server\MSSQL17.MSSQLSERVER\MSSQL\Binn\sqlservr.exe" -sMSSQLSERVER
ServiceAccount    : NT Service\MSSQLSERVER
State             : Running
```

Using “ Get-SQLInstanceLocal ” command we can see the state of database is running.

```
PS C:\PowerUpSQL-master\PowerUpSQL-master> Get-SQLQuery -Instance localhost -Query " SELECT name from sys.databases"

name
----
master
tempdb
model
msdb
PentestLab
```

Using `Get-SQLQuery -Instance localhost -Query " SELECT name from sys.databases"` we get what are the databases are available.

```
PS C:\PowerUpSQL-master\PowerUpSQL-master> Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT name FROM sys.tables; "

name
----
Users
```

Our target is pentestlab, So the command is `Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT name FROM sys.tables; "`. This command shows the table inside the pentestlab.

```
PS C:\PowerUpSQL-master\PowerUpSQL-master> Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT username, password_hash FROM Users; "

username password_hash
-----
admin    {36, 11, 229, 24...}
admin    {36, 11, 229, 24...}
admin    {36, 11, 229, 24...}
```

Using the command `Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT username, password_hash FROM Users; "`. Now we get the username and password in hash format.

```
PS C:\PowerUpSQL-master\PowerUpSQL-master> Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT username, CONVERT (varchar(64), password_hash,2) AS hash_hex FROM Users; "

username hash_hex
-----
admin    2488E518FABD2724DD86F04EEB1DA5967448D7E831C08C8FA822809F74C728A9
admin    2488E518FABD2724DD86F04EEB1DA5967448D7E831C08C8FA822809F74C728A9
admin    2488E518FABD2724DD86F04EEB1DA5967448D7E831C08C8FA822809F74C728A9
```

Now we must change the binary hash to hex hash. So the command is `"Get-SQLQuery -Instance localhost -Query " USE Pentestlab; SELECT username, CONVERT (varchar(64), password_hash,2) AS hash_hex FROM Users;"`

After changing the hash we store the hash in txt file.

Next tool is we are using john the ripper.

John the Ripper is a popular password-cracking tool that can be used to perform brute-force attacks using various encryption technologies and word lists. It's often what pen-testers and ethical hackers use to find the true passwords behind hashes.

```
(root@kali)-[/home/kali]
# john --format=RAW-SHA256 --wordlist=/home/kali/pentestlabwordlist.txt pentestlab.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA256 [SHA256 256/256 AVX2 8x])
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 7 candidates left, minimum 8 needed for performance.
admin123      (admin)
1g 0:00:00:00 DONE (2026-01-25 04:13) 8.333g/s 58.33p/s 58.33c/s 58.33C/s 12345678..admin123
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably
Session completed.
```

We store the hash in txt file called pentestlab.txt and pentestlabwordlist files contains thousands of possible passwords to crack.

John --format=RAW-SHA256 --wordlist=/home/kali/pentestlabwordlist.txt pentestlab.txt this command used to crack the hash into readable text.

After run the command we see the hash has been cracked and the password is **admin123**.

This is one of the method to crack the weak passwords.